

Planificación de Seguridad para el Sistema Financiero Finanzas — Backend Spring Boot + Frontend Angular sobre AWS

CE0321 — Seguridad · Área de Infraestructura Tecnológica

Estudiante:	CONDORI PACHAURI OMAR LLANQUE FLORES MERY ELIZABETH HUAHUACCAPA CCAMA JAQUELINE
Semestre:	IX
Docente:	
Fecha:	06/07/2026

Tabla de contenido

Tabla de contenido.....2

Resumen Ejecutivo3

Sección 1: Identificación de Activos Críticos4

1.1 Lista y clasificación de activos4

1.2 Criterios de clasificación7

Sección 2: Análisis de Riesgos8

2.1 Metodología.....8

2.2 Matriz de riesgos.....9

2.3 Resumen de riesgos por nivel12

2.4 Mapa de calor de riesgos12

2.5 Plan de tratamiento de riesgos13

Sección 3: Políticas de Seguridad.....14

3.1 Política de Control de Acceso.....14

3.2 Política de Seguridad de Datos15

3.3 Política de Gestión de Credenciales y Secretos.....16

3.4 Política de Seguridad de Red17

3.5 Política de Seguridad de Aplicaciones18

3.6 Política de Gestión de Incidentes.....19

3.7 Política de Seguridad Física (Cloud)20

3.8 Matriz de políticas vs. activos críticos.....20

Sección 4: Roles y Responsabilidades.....21

4.1 Estructura organizacional de seguridad21

4.2 Descripción de roles22

4.3 Matriz RACI23

4.4 Matriz de segregación de funciones (SOD).....25

4.5 Plan de capacitación en seguridad26

Anexos27

Anexo A: Matriz de riesgos completa27

Anexo B: Referencias a estándares.....30

Resumen Ejecutivo

Finanzas es un sistema de gestión financiera que procesa operaciones sensibles —ventas, compras, caja, cuentas corrientes, pago de personal, liquidaciones— para múltiples sucursales y puntos de venta. Por su naturaleza transaccional y financiera, la seguridad de la información no es un complemento opcional sino un requisito de primer orden: una brecha de seguridad puede traducirse en pérdidas económicas directas, fuga de datos personales protegidos por la Ley N.º 29733, y daño reputacional irreversible.

El sistema ya cuenta con una base de seguridad sólida implementada en su arquitectura actual: autenticación JWT con firma asimétrica RSA-256 (pares de llaves PEM), codificación de contraseñas con BCrypt, control de sesiones concurrentes (máximo 3 por usuario), bloqueo temporal de IP tras 5 intentos fallidos con cuarentena de 15 minutos, detección de IP sospechosa por cambio en ventana de 1 hora, registro de auditoría granular en tabla `lab_auditoria` para todas las operaciones de escritura, control de acceso por roles y permisos mediante `@PreAuthorize`, y monitoreo de intrusiones con tabla dedicada (`intrusion_attempts`). Adicionalmente, el frontend implementa guards de ruta (`auth guard`, `permission guard`) e interceptores HTTP que inyectan automáticamente el token JWT y manejan errores 401/403. Sin embargo, la seguridad de un sistema financiero no puede limitarse a la capa de autenticación. El presente plan de seguridad identifica siete dominios críticos que requieren atención: (1) seguridad perimetral de red —inexistente en el entorno de desarrollo actual—, (2) hardening de servidores y contenedores, (3) gestión de secretos y credenciales (actualmente expuestos en texto plano en `application.properties`), (4) protección de API contra ataques de capa 7 (rate limiting, validación de entrada, WAF), (5) seguridad en la mensajería Kafka, (6) cifrado robusto de base de datos, y (7) plan de respuesta a incidentes.

El diseño de topología definido en el entregable CE0311 —una VPC segmentada en 4 subredes con grupos de seguridad por capa y un proxy inverso Nginx como único punto de entrada— constituye la primera capa de defensa sobre la cual se construye esta planificación. Sobre esa base, se proponen controles técnicos y organizativos organizados en 4 ejes estratégicos: prevención (hardening, gestión de parches, cifrado), detección (monitoreo de logs, sistema de detección de intrusiones, alertas CloudWatch), respuesta (plan de incidentes, procedimientos de contención y recuperación), y cumplimiento (alineación con ISO/IEC 27001, Ley 29733, y estándares OWASP Top 10).

El plan contempla un cronograma de implementación por fases que prioriza las medidas de mayor impacto y menor costo en el corto plazo (gestión de secretos, rate limiting básico, headers de seguridad HTTP), dejando para fases posteriores las inversiones más significativas (WAF, HSM para llaves, SIEM). Se incluye además una matriz de riesgos con 15 escenarios identificados, cada uno con su probabilidad, impacto, nivel de riesgo, y controles propuestos, permitiendo al administrador del sistema tomar decisiones informadas sobre la priorización de cada medida.

El costo estimado de implementación de las medidas propuestas varía desde USD 0 (configuraciones de software libre como headers de seguridad, hardening de contenedores, rate limiting con Nginx) hasta aproximadamente USD 50–100/mes adicionales en servicios AWS si se opta por soluciones gestionadas (AWS WAF, AWS Secrets Manager, GuardDuty). Se documentan ambas alternativas —gratuita y gestionada— para que el responsable de infraestructura elija según el presupuesto disponible y el nivel de riesgo aceptable.

Sección 1: Identificación de Activos Críticos

1.1 Lista y clasificación de activos

A continuación se identifican y clasifican todos los activos de información, software, hardware, servicios y personas que conforman el ecosistema de Finanzas. Cada activo se evalúa según su criticidad para la operación del negocio (Crítico, Alto, Medio, Bajo) y el tipo de activo según la clasificación estándar de seguridad de la información (ISO/IEC 27001).

ID	Activo	Tipo	Descripción	Criticidad	Dependencias
A-01	Base de datos PostgreSQL (laboratorio_db)	Información	Almacena todas las transacciones financieras: ventas, compras, caja, cuentas corrientes, pagos, kardex, auditoría. ~17 tablas migradas + ~60 entidades JPA.	Crítico	A-04 (Backend), A-11 (Volumen EBS)
A-02	Esquema y migraciones Flyway (V1-V11)	Información	Definición del esquema de base de datos, integridad referencial, triggers y datos semilla.	Crítico	A-01
A-03	Llaves criptográficas RSA (pares PEM)	Información	Llave privada y pública para firma y verificación de tokens JWT. Almacenadas en keys/private_key.pem y keys/public_key.pem.	Crítico	A-05 (JWT)
A-04	Backend Spring Boot (código fuente)	Software	494 archivos Java, 64 controladores REST, 108 servicios de negocio, lógica transaccional financiera.	Crítico	A-12 (Repositorio Git)
A-05	Servicio de autenticación JWT (AuthService + JwtService)	Software	Módulo de login, registro, refresh token, generación y validación de tokens JWT con RSA-256.	Crítico	A-03, A-04, A-01
A-06	Módulo de seguridad perimetral (SecurityMonitor)	Software	Bloqueo de IP, detección de intrusiones, control de sesiones concurrentes, registro en intrusion_attempts.	Alto	A-04, A-01
A-07	Registro de auditoría (AuditLog / lab_auditoria)	Información	Trazabilidad completa de todas las operaciones de escritura: usuario, IP, acción, datos antes/después, timestamp.	Alto	A-04, A-01
A-08	Microservicio de notificaciones (Spring Boot 3.5.9)	Software	Consume eventos Kafka y los distribuye vía WebSocket STOMP a los clientes frontend.	Medio	A-09

A-09	Apache Kafka (topic sistema.notificaciones)	Infraestructura	Broker de mensajería asíncrona para el flujo de notificaciones en tiempo real.	Medio	A-04, A-08
A-10	Frontend Angular 20 (48 módulos funcionales)	Software	nterfaz de usuario con dashboards, reportes, CRUDs, WebSocket client. Compilado como SPA estática.	Alto	A-21 (Nginx)
A-11	Volumen EBS gp3 (30 GB)	Hardware virtual	Almacenamiento persistente de PostgreSQL, Kafka logs, y archivos de aplicación. Respaldo por snapshots diarios.	Crítico	A-04, A-01, A-09
A-12	Repositorio Git del proyecto	Información	Código fuente completo del backend, frontend y notificaciones, incluyendo configuración, migraciones y llaves.	Alto	Todos
A-13	Credenciales de base de datos (PostgreSQL)	nformación	Usuario y contraseña de conexión a la base de datos. Actualmente en application.properties.	Crítico	A-01
A-14	Credenciales de Gmail SMTP	Información	Usuario y contraseña para envío de correos electrónicos. Actualmente en application.properties.	Alto	A-04
A-15	Credenciales de Twilio (API)	Información	Account SID y Auth Token para integración WhatsApp/SMS. Actualmente en application.properties.	Medio	A-04
A-16	Datos personales de usuarios y empleados	Información	Nombres, DNI, direcciones, roles, asignación de sucursales. Protegidos por Ley 29733.	Crítico	A-01, A-05
A-17	Datos financieros transaccionales	Información	Ventas, compras, movimientos de caja, cuentas corrientes, pagos, liquidaciones, kardex.	Crítico	A-04
A-18	Documentos y archivos subidos (S3 / uploads)	Información	Comprobantes de pago (PDF), reportes exportados (PDF/Excel), evidencias.	Medio	A-04
A-19	Certificados TLS (Let's Encrypt)	Información	Certificados para HTTPS (Nginx). Renovación automática cada 60 días.	Alto	A-21
A-20	Configuración de la aplicación (application.properties)	Información	Configuración de BD, Kafka, JWT, seguridad, mail, Twilio, multipart, logging. Contiene credenciales en texto plano.	Crítico	A-04
A-21	Nginx (proxy inverso + TLS)	Software	Único punto de entrada desde internet. Terminación SSL, proxy reverso a backend, servidor de archivos estáticos.	Crítico	A-04, A-10, A-19
A-22	Instancia EC2 t3.medium	Hardware virtual	Servidor que aloja todos los contenedores Docker (Nginx, Backend, Notificaciones, PostgreSQL, Kafka).	Crítico	Todos los activos de infraestructura

A-23	VPC y configuración de red (subredes, SGs, NACLs)	raestructura	Segmentación de red: 4 subredes, 4 Security Groups, tablas de rutas, VPC Gateway Endpoint.	Crítico	A-22
A-24	Administradores del sistema	Personas	Usuarios con privilegios de administración: gestión de usuarios, roles, permisos, configuración global.	Crítico	A-05
A-25	Usuarios operativos por sucursal	Personas	Personal que realiza operaciones diarias: ventas, caja, compras, kardex.	Alto	A-05
A-26	Arquitectura y documentación del sistema	Información	ocumentación técnica del proyecto, diagramas, diseño de red, plan de seguridad.	Medio	odos

Matriz de clasificación por tipo de activo

Tipo de activo	Cantidad	Activos IDs
Información (datos, documentos, configuraciones, llaves)	13	A-01, A-02, A-03, A-07, A-12, A-13, A-14, A-15, A-16, A-17, A-18, A-19, A-20, A-26
Software (aplicaciones, módulos, servicios)	7	A-04, A-05, A-06, A-08, A-10, A-21
Infraestructura (servidores, redes, almacenamiento)	4	A-09, A-11, A-22, A-23
Personas (roles, usuarios, administradores)	2	A-24, A-25

Distribución de criticidad

Nivel	Cantidad	%
Crítico	14	54%
Alto	8	31%
Medio	4	15%
Bajo	0	0%
Total	26	10%

1.2 Criterios de clasificación

Nivel	Definición	Criterio
Crítico	Su indisponibilidad, pérdida o compromiso detiene completamente la operación del negocio o causa daño financiero/legal irreparable.	Afecta la continuidad del negocio, expone datos financieros o personales masivos, o impide la operación de todas las sucursales.
Alto	Su indisponibilidad o compromiso causa una degradación significativa del servicio o expone información sensible de forma limitada.	Afecta módulos específicos, degrada la experiencia de usuario, o expone datos de un subconjunto de usuarios.
Medio	Su indisponibilidad o compromiso causa molestias operativas pero no detiene el negocio ni expone datos críticos.	Afecta funcionalidades no esenciales (notificaciones, reportes históricos) o datos no sensibles.
Bajo	Su indisponibilidad o compromiso tiene un impacto mínimo o nulo en la operación.	Funcionalidades auxiliares, documentación, o datos públicos.

Sección 2: Análisis de Riesgos

2.1 Metodología:

El análisis de riesgos sigue los lineamientos de las normas ISO/IEC 27005:2022 (Gestión de Riesgos de Seguridad de la Información) y NIST SP 800-30 (Guide for Conducting Risk Assessments). Se evalúan 15 escenarios de riesgo identificados a partir del inventario de activos críticos de la Sección 1, considerando las amenazas más probables sobre un sistema financiero desplegado en cloud..

Escala de valoración

Nivel	Probabilidad	Impacto
Muy Alto (4)	Ocurre semanalmente o es casi seguro	Pérdida financiera > USD 10,000, daño legal, detención total del negocio
Alto (3)	Ocurre mensualmente o es probable	Pérdida financiera USD 1,000–10,000, exposición de datos personales, degradación severa
Medio (2)	Ocurre trimestralmente o es posible	Afecta funcionalidades no esenciales (notificaciones, reportes históricos) o datos no sensibles.
Bajo (1)	Ocurre anualmente o es improbable	Pérdida financiera < USD 100, afectación menor sin impacto al negocio

El nivel de riesgo se calcula como: $\text{Riesgo} = \text{Probabilidad} \times \text{Impacto}$

Rango	Nivel de riesgo	Acción requerida
12 – 16	Crítico	Mitigación inmediata (prioridad 1)
8 – 9	Alto	Mitigación planificada (prioridad 2)
4 – 6	Medio	Monitoreo y mejora continua
1 – 3	Bajo	Aceptar o monitorear

2.2 Matriz de riesgos

ID	Amenaza	Vulnerabilidad	Activo afectado	Prob.	Imp.	Nivel de riesgo	Control actual	Control propuesto
R-01	Filtración de llaves RSA privadas	Las llaves JWT se almacenan en archivos PEM dentro del classpath del backend (keys/private_key.pem), accesibles desde el repositorio Git y sin cifrado adicional.	A-03 (Llaves RSA), A-05 (JWT)	2	4	8 (Alto)	Ninguno (las llaves están en texto plano dentro del proyecto)	Migrar llaves a AWS Secrets Manager o HSM (CloudHSM). Rotación automática cada 90 días. Eliminar llaves del repositorio Git y del classpath.
R-02	Exposición de credenciales en texto plano	application.properties contiene usuario/contraseña de PostgreSQL, credenciales de Gmail SMTP y tokens de Twilio en texto plano sin cifrar.	A-13, A-14, A-15, A-20	3	4	12 (Crítico)	Ninguno (credenciales hardcodeadas)	Migrar todas las credenciales a variables de entorno o AWS Secrets Manager. Implementar políticas de IAM para acceso a secretos. Rotación periódica.
R-03	Ataque de fuerza bruta al login	El endpoint /api/auth/login no tiene rate limiting configurado. Aunque existe bloqueo por IP tras 5 intentos, un ataque distribuido (DDoS de autenticación) puede eludirlo.	A-05 (JWT), A-24 (Usuarios)	3	3	9 (Alto)	Bloqueo de IP tras 5 intentos fallidos (15 min). Control de sesiones concurrentes (máx. 3).	Implementar rate limiting en Nginx (límite por IP, por usuario, por endpoint). Agregar Cloudflare o AWS WAF con reglas de rate-based blocking.
R-04	Inyección SQL	El sistema usa JPA/Hibernate que previene inyección SQL en consultas parametrizadas, pero las consultas nativas y procedimientos almacenados no están auditados.	A-01 (PostgreSQL)	2	4	8 (Alto)	JPA/Hibernate con parámetros tipados.	Auditoría de todas las consultas nativas (JPQL nativo, @Query con SQL puro). Implementar WAF con reglas SQL injection. Pruebas de penetración trimestrales.
R-05	Ataque XSS (Cross-Site Scripting)	El frontend Angular tiene protección integrada contra XSS (sanitización automática de templates), pero los reportes exportados en PDF/HTML podrían inyectar scripts si los datos no se sanitizan al generarlos.	A-10 (Frontend), A-18 (Documentos)	2	3	6 (Medio)	Sanitización automática de Angular en templates.	Implementar Content Security Policy (CSP) estricta en Nginx. Sanitizar datos de entrada antes de generar PDFs/Excel.

ID	Amenaza	Vulnerabilidad	Activo afectado	Prob.	Imp.	Nivel de riesgo	Control actual	Control propuesto
								Validar datos en backend antes de devolverlos.
R-06	Ataque de denegación de servicio (DoS/DDoS)	La instancia EC2 t3.medium tiene un solo punto de entrada (Nginx) sin protección contra ataques volumétricos ni escalado automático.	A-21 (Nginx), A-22 (EC2)	3	3	9 (Alto)	Ninguno (la instancia está directamente expuesta a internet con protección mínima)	Implementar AWS WAF + AWS Shield Standard (gratuito). Configurar rate limiting en Nginx. Usar CloudFront como CDN con protección DDoS.
R-07	Acceso no autorizado a Kafka	Kafka se ejecuta sin autenticación ni cifrado (puerto 9092 abierto dentro de la VPC). Cualquier servicio en la misma red podría producir/consumir mensajes del topic sistema.notificaciones.	A-09 (Kafka)	2	3	6 (Medio)	Aislamiento por Security Group (solo SG-App accede al puerto 9092).	Habilitar SSL/TLS en Kafka para cifrado en tránsito. Configurar SASL/SCRAM para autenticación. Migrar a Amazon MSK con cifrado y autenticación gestionados.
R-08	Intercepción de tráfico interno VPC	El tráfico entre servicios (backend ↔ PostgreSQL, backend ↔ Kafka) viaja en texto plano dentro de la VPC. Aunque la VPC está aislada, un atacante con acceso a la instancia podría capturar tráfico.	A-01, A-04, A-08, A-09	2	3	6 (Medio)	Aislamiento de VPC.	Habilitar cifrado SSL/TLS en conexiones PostgreSQL (ssl=true). Cifrar comunicación con Kafka. Considerar VPC Traffic Mirroring para monitoreo.
R-09	Fuga de datos por error en el registro de auditoría	La tabla lab_auditoria registra datos sensibles (oldData, newData) sin cifrado. Si un atacante accede a la BD, puede leer el historial completo de cambios de datos financieros.	A-07 (AuditLog), A-01	2	4	8 (Alto)	Control de acceso a la BD por Security Group.	Cifrar columnas sensibles en lab_auditoria (cifrado a nivel de aplicación o PostgreSQL pgcrypto). Implementar política de retención y purge automático de auditoría > 1 año.
R-10	Suplantación de identidad (token theft)	El token JWT se almacena en localStorage del navegador. Un ataque XSS (aunque mitigado) o un script malicioso de extensión podría robar el token y suplantar al usuario.	A-05 (JWT), A-24, A-25	3	4	12 (Crítico)	Token con expiración de 30 minutos. Refresh token con rotación.	Migrar almacenamiento de token de localStorage a HttpOnly cookies (con Secure y SameSite=Strict). Implementar boundary tokens (vincular token a características de la sesión: IP, User-Agent).
R-11	Acceso root a la instancia EC2 por SSH expuesto	El puerto SSH (22) está abierto a internet (SG-Mgmt permite acceso desde IP del administrador). Si la IP del administrador es comprometida o cambia, la instancia queda accesible.	A-22 (EC2)	2	4	8 (Alto)	Security Group restringe SSH a IP del administrador.	Deshabilitar SSH por internet completamente. Usar solo AWS Systems Manager (SSM) Session Manager para acceso administrativo (sin puertos abiertos, sin bastion host, con auditoría integrada).
R-12	Corrupción de base de datos por migración fallida	Las migraciones Flyway se ejecutan automáticamente al iniciar el backend. Una migración fallida o un script mal escrito puede corromper datos existentes.	A-01, A-02	2	4	8 (Alto)	Flyway con out-of-order=false. Snapshots diarios EBS.	Implementar entorno de staging para validar migraciones antes de producción. Agregar checksums de integridad a las

ID	Amenaza	Vulnerabilidad	Activo afectado	Prob.	Imp.	Nivel de riesgo	Control actual	Control propuesto
								migraciones. Probar rollback de migraciones (Flyway undo no es nativo, requiere scripts manuales).
R-13	Violación de datos personales (Ley 29733)	La base de datos almacena datos personales (nombres, DNI, direcciones) sin cifrado en reposo a nivel de columna. Un acceso no autorizado a la BD expone estos datos.	A-16 (Datos personales)	2	4	8 (Alto)	Cifrado en reposo del volumen EBS. Control de acceso por roles.	Implementar cifrado a nivel de columna en PostgreSQL (pgcrypto) para DNI, direcciones y datos sensibles. Enmascarar datos personales en logs y auditoría.
R-14	Suplantación de sesión por fijación de sesión (session fixation)	El sistema no renueva el token JWT después de operaciones sensibles (cambio de sucursal, cambio de punto de venta). Un atacante podría fijar un token antes del cambio de contexto.	A-05 (JWT), A-24, A-25	1	3	3 (Bajo)	El token incluye idSucursal y idPunto como claims.	Renovar el token JWT completo después de cada cambio de sucursal o punto de venta (ya implementado en AuthSucursalService pero debe verificarse).
R-15	Falta de segregación de funciones en operaciones financieras	Un mismo usuario puede tener permisos para crear y aprobar una misma operación (ej. crear un descuento y autorizarlo) si tiene los roles combinados. Esto viola el principio de segregación de funciones.	A-04 (Backend), A-24, A-25	2	3	6 (Medio)	Control de permisos por rol (@PreAuthorize).	Implementar matriz SOD (Segregation of Duties): definir reglas de conflicto (ej. "quien crea no puede aprobar"). Validar SOD antes de asignar roles a un usuario. Registrar violaciones SOD en auditoría.

2.3 Resumen de riesgos por nivel

Nivel de riesgo	Cantidad	ID de riesgos
Crítico (12–16)	2	R-02, R-10
Alto (8–9)	8	R-01, R-03, R-04, R-06, R-09, R-11, R-12, R-13
Medio (4–6)	4	R-05, R-07, R-08, R-15
Bajo (1–3)	1	R-14
Total	15	

2.4 Mapa de calor de riesgos

Probabilidad \ Impacto	Bajo (1)	Medio (2)	Alto (3)	Muy Alto (4)
Muy Alto (4)	—	—	—	—
Alto (3)	—	—	R-03, R-06	R-02, R-10

Probabilidad \ Impacto	Bajo (1)	Medio (2)	Alto (3)	Muy Alto (4)
Medio (2)	—	—	R-05, R-07, R-08, R-15	R-01, R-04, R-09, R-11, R-12, R-13
Bajo (1)	—	—	R-14	—

2.5 Plan de tratamiento de riesgos

Prioridad	ID	Medida	Tipo de tratamiento	Responsable	Plazo	Costo estimado
1	R-02	Migrar credenciales a Secrets Manager + variables de entorno	Reducción	Administrador del sistema	1 semana	USD 0 – 4/mes (Secrets Manager)
1	R-10	Migrar token JWT de localStorage a HttpOnly cookie	Reducción	Desarrollador backend/frontend	2 semanas	USD 0
2	R-03	Rate limiting en Nginx + AWS WAF	Reducción	Administrador de infraestructura	1 semana	USD 0 (Nginx) – 20/mes (WAF)
2	R-06	AWS Shield + CloudFront + rate limiting	Reducción	Administrador de infraestructura	2 semanas	USD 0 (Shield Std) – 30/mes (WAF)
2	R-01	Migrar llaves RSA a Secrets Manager + rotación automática	Reducción	Administrador del sistema	1 semana	USD 0 – 4/mes
2	R-11	Deshabilitar SSH público, migrar a SSM Session Manager	Reducción	Administrador de infraestructura	2 días	USD 0
3	R-04	Auditoría de consultas nativas + WAF SQL injection	Reducción	Desarrollador backend	1 mes	USD 0 (auditoría) – 20/mes (WAF)
3	R-09	Cifrar columnas sensibles en auditoría + política de retención	Reducción	Desarrollador backend	2 semanas	USD 0
3	R-12	Entorno staging + rollback de migraciones	Reducción	Desarrollador backend	1 mes	USD 0 (staging en misma cuenta)
3	R-13	Cifrado a nivel de columna (pgcrypto) + enmascaramiento	Reducción	Desarrollador backend	3 semanas	USD 0
4	R-07	SSL/TLS + SASL en Kafka	Reducción	Administrador de infraestructura	2 semanas	USD 0 (configuración)
4	R-08	SSL en PostgreSQL + cifrado en comunicación Kafka	Reducción	Administrador de infraestructura	1 semana	USD 0
4	R-15	Implementar matriz SOD en asignación de roles	Reducción	Desarrollador backend	3 semanas	USD 0
5	R-05	CSP estricta + sanitización en generación de reportes	Reducción	Desarrollador frontend	2 semanas	USD 0
5	R-14	Verificar renovación de token en cambio de sucursal	Reducción	Desarrollador backend	3 días	USD 0

Sección 3: Políticas de Seguridad

3.1 Política de Control de Acceso

ID	Política	Descripción
P-AC-01	Principio de mínimo privilegio	Todo usuario del sistema recibirá únicamente los permisos estrictamente necesarios para cumplir sus funciones laborales. Ningún usuario podrá tener permisos que excedan su rol definido.
P-AC-02	Autenticación multifactor (MFA)	El acceso a la consola de AWS y al panel de administración del sistema requerirá autenticación multifactor. Para usuarios operativos, se considera MFA basado en conocimiento (contraseña + token JWT con contexto de sucursal).
P-AC-03	Sesiones concurrentes	Se mantiene el límite de máximo 3 sesiones concurrentes por usuario. Al exceder este límite, la sesión más antigua será invalidada automáticamente.

ID	Política	Descripción
P-AC-04	Bloqueo por intentos fallidos	Tras 5 intentos fallidos de inicio de sesión en un período de 15 minutos, la IP origen será bloqueada temporalmente por 15 minutos. Tras 10 intentos fallidos acumulados en 1 hora, el usuario será bloqueado hasta que un administrador lo desbloquee manualmente.
P-AC-05	Caducidad de contraseñas	Las contraseñas de los usuarios expirarán cada 90 días. El sistema obligará al cambio de contraseña al primer inicio de sesión y después de cada restablecimiento de contraseña por parte del administrador.
P-AC-06	Complejidad de contraseñas	Las contraseñas deberán tener un mínimo de 8 caracteres, incluyendo al menos una letra mayúscula, una letra minúscula, un dígito y un carácter especial. Se verificará contra una lista de contraseñas comunes (rockyou top 1000) para evitar su uso.
P-AC-07	Cierre de sesión por inactividad	Las sesiones web expirarán automáticamente después de 30 minutos de inactividad. El usuario deberá autenticarse nuevamente para continuar. Se mostrará una advertencia 5 minutos antes de la expiración.
P-AC-08	Control de acceso por sucursal	Un usuario autenticado solo podrá acceder a los datos y operaciones de la sucursal a la que está asignado. El cambio de sucursal requerirá una nueva autenticación con confirmación de contraseña (ya implementado en AuthSucursalService).
P-AC-09	Registro de accesos	Todo inicio de sesión exitoso y fallido será registrado en la tabla sessions y en la auditoría (lab_auditoria), incluyendo: usuario, IP origen, User-Agent, timestamp, sucursal, y resultado (éxito/fallo).

3.2 Política de Seguridad de Datos

ID	Política	Descripción
P-DT-01	Clasificación de datos	Todos los datos del sistema se clasificarán en cuatro niveles: Público (reportes agregados sin datos sensibles), Interno (procedimientos, documentación técnica), Confidencial (datos financieros transaccionales, datos de contacto), y Restringido (llaves criptográficas, credenciales, datos personales con DNI). Cada nivel tendrá controles de protección específicos.
P-DT-02	Cifrado en reposo	Todos los datos clasificados como Confidenciales o Restringidos deberán almacenarse cifrados en reposo. Se implementará: (a) cifrado del volumen EBS (por defecto en AWS), (b) cifrado de buckets S3 (SSE-S3 o SSE-KMS), (c) cifrado a nivel de columna en PostgreSQL (pgcrypto) para DNI, direcciones y datos biométricos.
P-DT-03	Cifrado en tránsito	Todas las comunicaciones entre componentes del sistema deberán viajar cifradas: (a) HTTPS (TLS 1.2+) entre cliente y servidor, (b) SSL/TLS en conexiones PostgreSQL, (c) SSL/TLS + SASL en Kafka, (d) STARTTLS en conexiones SMTP.
P-DT-04	Retención de datos	Los datos transaccionales se conservarán por un mínimo de 5 años (exigencia contable y fiscal peruana). El registro de auditoría se conservará por 3 años. Los logs de aplicación se conservarán por 90 días. Los datos personales se eliminarán 1 año después de que el usuario cese su relación con el sistema, salvo obligación legal de retención.
P-DT-05	Minimización de datos	Solo se recolectarán los datos estrictamente necesarios para la operación del sistema financiero. No se almacenarán datos sensibles no requeridos (ej. número de tarjeta de crédito, preguntas secretas) a menos que la legislación lo exija explícitamente.
P-DT-06	Enmascaramiento de datos	Los datos personales (DNI, teléfono, correo) deberán mostrarse enmascarados en las interfaces de usuario que no requieran el valor completo para su función. Ejemplo: ***1234 para DNI, o***@gmail.com para correo. Los datos completos solo se mostrarán en módulos autorizados explícitamente (ej. detalle de empleado para RRHH).
P-DT-07	Respaldo y recuperación	Se realizarán respaldos diarios automáticos de la base de datos (snapshot EBS vía DLM) con retención de 7 días. Semanalmente se generará un respaldo adicional con retención mensual. Los respaldos se almacenarán en una región AWS secundaria (us-west-2) para protección ante desastre regional.

3.3 Política de Gestión de Credenciales y Secretos

ID	Política	Descripción
P-CR-01	Prohibición de secretos en código fuente	Queda terminantemente prohibido almacenar contraseñas, tokens, llaves API, certificados o cualquier secreto en el código fuente, archivos de configuración versionados, o archivos dentro del classpath de la aplicación. Todos los secretos deberán gestionarse a través de AWS Secrets Manager o variables de entorno inyectadas en tiempo de ejecución.
P-CR-02	Rotación periódica de secretos	Las credenciales de base de datos se rotarán cada 90 días. Los tokens de API (Twilio) se rotarán cada 180 días. Las llaves RSA de JWT se rotarán cada 90 días. Las credenciales SMTP se rotarán inmediatamente si hay indicios de compromiso.
P-CR-03	Gestión de llaves criptográficas	Las llaves RSA utilizadas para firma JWT se generarán con una longitud mínima de 2048 bits. La llave privada se almacenará exclusivamente en AWS Secrets Manager con cifrado KMS gestionado por AWS. La llave pública podrá distribuirse libremente. Se mantendrá un historial de llaves anteriores para permitir la validación de tokens emitidos antes de una rotación.
P-CR-04	Acceso bajo demanda a secretos	El acceso a los secretos almacenados en Secrets Manager se concederá únicamente a las instancias EC2 y servicios que los requieran, mediante políticas de IAM con permisos de mínimo privilegio. Ningún desarrollador o administrador podrá leer secretos de producción sin autorización explícita y registro en auditoría.

3.4 Política de Seguridad de Red

ID	Política	Descripción
P-RD-01	Segmentación por zonas de seguridad	La red se segmentará en cuatro zonas con niveles de confianza decrecientes: (1) DMZ — público, solo Nginx, (2) Aplicación — backend y microservicios, (3) Datos — bases de datos y colas de mensajería, (4) Gestión — acceso administrativo. El tráfico entre zonas será explícitamente autorizado por Security Groups y denegado por defecto.
P-RD-02	Denegación por defecto	Todo el tráfico entrante y saliente está denegado por defecto. Solo se permitirán explícitamente las conexiones necesarias para la operación del sistema, documentadas en la matriz de puertos de la Sección 2.3 del CE0311.
P-RD-03	Monitoreo de tráfico de red	Se habilitará VPC Flow Logs para registrar todo el tráfico de red de la VPC. Los logs se enviarán a CloudWatch Logs y se conservarán por 90 días. Se configurarán alarmas para detectar patrones anómalos: tráfico saliente a IPs sospechosas, múltiples conexiones desde una misma IP, escaneo de puertos.
P-RD-04	Acceso administrativo sin SSH público	El acceso SSH directo a la instancia EC2 desde internet queda prohibido. Todo acceso administrativo se realizará exclusivamente a través de AWS Systems Manager Session Manager (SSM), que proporciona: (a) túneles cifrados sin exponer puertos, (b) registro completo de sesiones en CloudTrail, (c) control de acceso mediante políticas IAM, (d) posibilidad de restringir comandos específicos.
P-RD-05	Protección contra escaneo de puertos	Se configurarán reglas en el Network ACL de la subred pública para limitar la tasa de conexiones entrantes. Se implementará un sistema de fail2ban en Nginx para bloquear IPs que realicen escaneo de puertos o múltiples intentos de conexión a puertos no expuestos.

3.5 Política de Seguridad de Aplicaciones

ID	Política	Descripción
P-AP-01	Validación de entrada	Toda entrada de datos proveniente del cliente (formularios, parámetros de URL, cabeceras HTTP) será validada tanto en el frontend (validación de formularios) como en el backend (validación con Jakarta Bean Validation + sanitización adicional). Se rechazarán entradas que no cumplan el formato esperado sin revelar información interna.
P-AP-02	Protección contra OWASP Top 10	El sistema implementará controles específicos para las 10 vulnerabilidades más críticas según OWASP: Inyección (JPA parametrizado), Autenticación rota (JWT + rate limiting), Exposición de datos sensibles (cifrado), XXE (deshabilitado por defecto en Jackson), Control de acceso roto (@PreAuthorize), Configuración insegura (hardening checklist), XSS (Angular sanitization + CSP), Deserialización insegura (validación en Jackson), Componentes vulnerables (escaner de dependencias), Logging y monitoreo insuficiente (auditoría + CloudWatch).
P-AP-03	Cabeceras de seguridad HTTP	Nginx incluirá las siguientes cabeceras de seguridad en todas las respuestas HTTP: Strict-Transport-Security: max-age=31536000; includeSubDomains, X-Content-Type-Options: nosniff, X-Frame-Options: DENY, X-XSS-Protection: 1; mode=block, Content-Security-Policy: default-src 'self', Referrer-Policy: strict-origin-when-cross-origin, Permissions-Policy: geolocation=(), camera=(), microphone=().
P-AP-04	Gestión de dependencias vulnerables	Se implementará un proceso de escaneo automático de dependencias utilizando OWASP Dependency-Check integrado en el pipeline de Maven (pom.xml). Las vulnerabilidades críticas (CVSS >= 7.0) deberán corregirse en un plazo máximo de 7 días. Se mantendrá un inventario actualizado de todas las dependencias y sus versiones.
P-AP-05	Pruebas de seguridad	Se realizarán pruebas de penetración (pentest) trimestrales sobre el backend y frontend. Se ejecutarán escaneos de vulnerabilidades automatizados semanalmente (ZAP, Nikto). Las vulnerabilidades encontradas se clasificarán por severidad y se asignarán para corrección según el SLA definido: Crítico (48 horas), Alto (7 días), Medio (30 días), Bajo (90 días).

3.6 Política de Gestión de Incidentes

ID	Política	Descripción
P-IN-01	Clasificación de incidentes	Los incidentes de seguridad se clasificarán en cuatro niveles: Crítico (compromiso de datos financieros, acceso no autorizado a base de datos, exposición de llaves privadas), Alto (denegación de servicio, compromiso de cuenta de administrador), Medio (intentos de intrusión, escaneo de puertos), Bajo (phishing a usuarios, spam).
P-IN-02	Tiempos de respuesta	Los incidentes deberán ser reportados al administrador del sistema dentro de los siguientes plazos desde su detección: Crítico (inmediato, < 15 minutos), Alto (< 1 hora), Medio (< 24 horas), Bajo (< 72 horas). La resolución del incidente tendrá los siguientes SLA: Crítico (4 horas), Alto (24 horas), Medio (7 días), Bajo (30 días).
P-IN-03	Procedimiento de respuesta	Todo incidente seguirá el ciclo PDR (Prepare, Detect, Respond, Recover): (1) preparación — runbooks documentados, contactos de emergencia, (2) detección — alertas CloudWatch, logs de auditoría, reportes de usuarios, (3) respuesta — contención, análisis forense, erradicación, (4) recuperación — restauración desde respaldo, verificación de integridad, lecciones aprendidas.
P-IN-04	Notificación a autoridades	En caso de violación de datos personales, se notificará a la Autoridad Nacional de Protección de Datos Personales (Perú) dentro de las 72 horas siguientes a la confirmación del incidente, según lo establecido en la Ley N.° 29733 y su reglamento. Los titulares de los datos afectados serán notificados individualmente.
P-IN-05	Evidencia forense	Ante un incidente crítico, se preservará la evidencia digital para fines forenses: (a) snapshot del volumen EBS de la instancia afectada, (b) exportación de logs de CloudWatch y VPC Flow Logs, (c) registro de sesiones de SSM, (d) dump de la tabla intrusion_attempts y sessions. Todo el manejo de evidencia seguirá la cadena de custodia documentada.

3.7 Política de Seguridad Física (Cloud)

ID	Política	Descripción
P-FI-01	Responsabilidad compartida AWS	Se reconoce que AWS es responsable de la seguridad física de los centros de datos (acceso a instalaciones, vigilancia, control de temperatura, energía redundante). El equipo del proyecto es responsable de la seguridad lógica de los recursos desplegados en AWS (configuración de VPC, IAM, Security Groups, cifrado).
P-FI-02	Bloqueo de cuenta AWS	Se configurarán alertas de presupuesto (AWS Budgets) con umbrales al 50%, 80% y 100% del presupuesto mensual. Se habilitará AWS CloudTrail para auditoría de todas las acciones de la API de AWS. Se configurará una alarma de root activity para detectar cualquier uso de la cuenta root.

3.8 Matriz de políticas vs. activos críticos

Activo	Políticas aplicables
A-01 (PostgreSQL)	P-DT-01, P-DT-02, P-DT-03, P-DT-04, P-DT-07, P-AP-01
A-03 (Llaves RSA)	P-CR-01, P-CR-02, P-CR-03, P-CR-04
A-04 (Backend Spring Boot)	P-AC-01 a P-AC-09, P-AP-01, P-AP-02, P-AP-04, P-AP-05
A-05 (JWT)	P-AC-01 a P-AC-09, P-CR-03
A-07 (Auditoría)	P-DT-04, P-DT-06, P-IN-01, P-IN-05
A-10 (Frontend Angular)	P-AC-07, P-AP-01, P-AP-02, P-AP-05
A-21 (Nginx)	P-AP-03, P-RD-05
A-22 (EC2)	P-AC-02, P-RD-04, P-IN-03, P-FI-01
A-23 (VPC y red)	P-RD-01, P-RD-02, P-RD-03

Sección 4: Roles y Responsabilidades

4.1 Estructura organizacional de seguridad

La administración de seguridad del sistema Finanzas se organiza en tres niveles, siguiendo el modelo de defensa en profundidad aplicado a la gestión de roles:



4.2 Descripción de roles

Rol	Responsabilidades clave	Habilidades requeridas	Reporta a
Comité de Seguridad de la Información (CSI)	— Aprobar políticas y normas de seguridad del sistema — Revisar y aprobar el plan anual de seguridad — Autorizar inversiones en controles de seguridad	Visión estratégica, conocimiento de negocio financiero	Dirección General

	— Revisar incidentes críticos y lecciones aprendidas — Definir apetito y tolerancia al riesgo	Conocimiento de marco normativo (Ley 29733, ISO 27001)	
Administrador del Sistema (CISO funcional)	— Gestionar usuarios, roles, permisos y perfiles de acceso — Configurar y supervisar políticas de seguridad del backend — Monitorear la tabla lab_auditoria y detectar anomalías — Responder a incidentes de seguridad nivel 1 y 2 — Ejecutar el plan de respuesta a incidentes — Gestionar rotación de llaves RSA y credenciales	Spring Security, JWT, RBAC PostgreSQL, Flyway Conocimiento de OWASP Top 10 Gestión de incidentes	CSI
Administrador de Infraestructura (Cloud/Seguridad)	— Configurar y mantener la VPC, subredes, SGs y NACLs — Administrar la instancia EC2, volúmenes EBS y snapshots — Monitorear CloudWatch, VPC Flow Logs y alarmas — Aplicar parches de seguridad al sistema operativo y contenedores — Gestionar backups y pruebas de recuperación — Implementar controles de red (WAF, rate limiting, fail2ban)	AWS (VPC, EC2, S3, IAM, CloudWatch) Linux (Ubuntu), Docker, Nginx Redes, TCP/IP, DNS, TLS Seguridad cloud (AWS Well-Architected)	CSI
Oficial de Protección de Datos (DPO)	— Velar por el cumplimiento de la Ley N.º 29733 y su reglamento — Atender reclamos y solicitudes de titulares de datos (ARCO) — Reportar violaciones de datos a la Autoridad Nacional — Realizar evaluaciones de impacto a la privacidad (EIP)	Ley 29733, normativa peruana de protección de datos ISO/IEC 27701 Conocimiento del sistema y sus datos	CSI / Dirección Legal
Desarrollador Backend	— Implementar controles de seguridad en el código Spring Boot — Realizar code review con enfoque de seguridad — Corregir vulnerabilidades identificadas en pentests — Escribir migraciones Flyway seguras y auditables	Java 21, Spring Security, JPA JWT, RSA, BCrypt OWASP Top 10, pruebas unitarias y de integración	Administrador del Sistema
Desarrollador Frontend	— Implementar guards de ruta, interceptores y manejo seguro de tokens — Sanitizar datos de entrada y salida en la interfaz — Implementar CSP y cabeceras de seguridad en el frontend	Angular 20, TypeScript, RxJS OWASP Top 10 (XSS, CSRF) WebSockets seguros	Administrador del Sistema

Usuario Operativo	— Usar el sistema de acuerdo con las políticas de seguridad establecidas — No compartir credenciales con otros usuarios — Reportar actividades sospechosas al administrador — Cerrar sesión al finalizar su turno	Manejo del sistema Finanzas Conocimiento básico de seguridad informática	Jefe de Sucursal
Auditor Externo	— Realizar pruebas de penetración (pentest) trimestrales — Verificar el cumplimiento de políticas y controles — Emitir informes de hallazgos y recomendaciones	Pentest, OWASP Testing Guide ISO 27001, SOC 2 Auditoría de sistemas financieros	CSI

4.3 Matriz RACI

La matriz RACI (Responsible, Accountable, Consulted, Informed) define quién es responsable de ejecutar cada tarea, quién rinde cuentas por ella, quién debe ser consultado y quién debe ser informado.

Actividad / Control	CSI	Adm. Sistema	Adm. Infra.	DPO	Des. Back.	Des. Front.	Usu. Oper.	Aud. Ext.
Políticas de seguridad								
Aprobar políticas de seguridad	A	R	C	C	I	I	I	C
Redactar y mantener políticas	I	R/A	C	C	C	C	I	C
Difundir políticas a usuarios	I	R/A	I	C	I	I	I	I
Revisar políticas anualmente	A	R	C	C	C	C	I	C
Control de acceso								
Crear y eliminar usuarios	I	R/A	I	I	I	I	I	I
Asignar roles y permisos	I	R/A	I	C	I	I	C	I
Revisar accesos trimestralmente	I	R	I	C	I	I	I	A
Bloquear/desbloquear IPs	I	R/A	C	I	I	I	I	I
Gestión de secretos								
Rotar llaves RSA (JWT)	I	R/A	C	I	I	I	I	I
Rotar credenciales BD	I	R	A	I	I	I	I	I

Auditar acceso a secretos	I	R	R	I	I	I	I	A
Seguridad de red								
Configurar VPC/SGs/NACLs	I	C	R/A	I	I	I	I	C
Monitorear VPC Flow Logs	I	C	R/A	I	I	I	I	I
Implementar WAF / rate limiting	I	C	R/A	I	I	I	I	I
Gestionar certificados TLS	I	I	R/A	I	I	I	I	I
Seguridad de aplicaciones								
Implementar validación de entrada	I	C	I	I	R/A	R/A	I	C
Implementar cabeceras HTTP seguras	I	C	A	I	I	R	I	I
Escanear dependencias vulnerables	I	A	I	I	R	R	I	C
Corregir vulnerabilidades	I	A	I	I	R	R	I	C
Monitoreo y detección								
Monitorear logs de auditoría	I	R/A	C	C	I	I	I	C
Configurar alarmas CloudWatch	I	C	R/A	I	I	I	I	I
Revisar intentos de intrusión	I	R/A	C	I	I	I	I	I
Respuesta a incidentes								
Reportar incidente	I	A	A	C	R	R	R	I
Clasificar incidente	A	R	R	C	I	I	I	C
Contener y erradicar	I	R	R/A	I	C	C	I	I
Recuperar servicio	I	I	R/A	I	C	C	I	I
Notificar a autoridades (violación datos)	A	C	I	R	I	I	I	C
Documentar lecciones aprendidas	A	R	R	C	C	C	I	C
Cumplimiento y auditoría								
Realizar pentest trimestral	A	C	C	C	I	I	I	R
Realizar EIP (privacidad)	I	C	I	R/A	I	I	I	C

Reportar cumplimiento normativo	A	C	I	R	I	I	I	C
Capacitación								
Capacitar usuarios en seguridad	I	R/A	I	C	I	I	I	I
Capacitar desarrolladores (seguro)	I	R/A	I	I	I	I	I	I
Simulacro de incidentes anual	A	R	R	C	C	C	C	C

Leyenda:

- R = Responsable (ejecuta la actividad)
- A = Accountable (rinde cuentas, es el dueño de la actividad)
- C = Consulted (debe ser consultado antes de ejecutar)
- I = Informed (debe ser informado después de ejecutar)

4.4 Matriz de segregación de funciones (SOD)

Para evitar conflictos de interés y cumplir con el principio de segregación de funciones (SoD), las siguientes combinaciones de roles están prohibidas en un mismo usuario:

Combinación prohibida	Riesgo	Mitigación
Administrador del Sistema + Usuario Operativo	El administrador podría otorgarse permisos para realizar y ocultar operaciones financieras fraudulentas	Separación de cuentas: el administrador usa una cuenta administrativa y una cuenta operativa distinta
Crear Usuario + Asignar Roles + Auditor	Podría crear un usuario con privilegios, asignarle roles, y luego eliminar las trazas de auditoría	La auditoría se almacena en tabla inmutable con acceso de solo lectura para el auditor
Desarrollador Backend + Administrador de Infraestructura	Podría desplegar código malicioso directamente en producción sin revisión	Pipeline CI/CD con code review obligatorio; el desarrollador no tiene acceso directo a producción
Operador de Ventas + Autorizador de Descuentos	Podría crear una venta con descuento irregular y auto-aprobarla	Flujo de autorización requiere dos usuarios distintos (ya implementado en autorizar-descuento)

4.5 Plan de capacitación en seguridad

Rol	Frecuencia	Temas	Modalidad
Usuarios operativos	Anual (al ingreso y refuerzo anual)	Política de contraseñas, cómo reportar incidentes, phishing, no compartir credenciales, cierre de sesión	Presencial / Virtual + evaluación

Administradores (Sistema + Infraestructura)	Semestral	OWASP Top 10, hardening de servidores, respuesta a incidentes, gestión de secretos, AWS Well-Architected	Taller práctico
Desarrolladores	Semestral	Codificación segura, OWASP Top 10, revisión de dependencias, pruebas de seguridad	Taller práctico + code review guiado
Comité de Seguridad	Anual	Tendencias de amenazas, actualización normativa, lecciones aprendidas de incidentes	Sesión ejecutiva

Anexos

Anexo A: Matriz de riesgos completa

ID	Activo afectado	Amenaza	Vulnerabilidad	Prob.	Imp.	Nivel	Control actual	Control propuesto	Prior.
R-01	A-03 (Llaves RSA), A-05 (JWT)	Filtración de llaves RSA privadas	Llaves almacenadas en archivos PEM dentro del classpath, accesibles desde el repositorio Git sin cifrado adicional	2	4	8 (Alto)	Ninguno	Migrar llaves a AWS Secrets Manager o CloudHSM. Rotación automática cada 90 días. Eliminar llaves del repositorio.	2
R-02	A-13 (Cred. BD), A-14 (Cred. SMTP), A-15 (Cred. Twilio), A-20 (Config)	Exposición de credenciales en texto plano	application.properties contiene usuario/contraseña de BD, credenciales SMTP y tokens Twilio en texto plano	3	4	12 (Crítico)	Ninguno (credenciales hardcodeadas)	Migrar a AWS Secrets Manager + variables de entorno. Rotación periódica. Políticas IAM de mínimo privilegio para acceso a secretos.	1
R-03	A-05 (JWT), A-24 (Admin), A-25 (Usuarios)	Ataque de fuerza bruta al login	Endpoint /api/auth/login sin rate limiting. Bloqueo por IP eludible con ataque distribuido	3	3	9 (Alto)	Bloqueo de IP tras 5 intentos fallidos (15 min). Máx. 3 sesiones concurrentes	Rate limiting en Nginx (límite por IP, por usuario, por endpoint). AWS WAF con rate-based blocking.	2
R-04	A-01 (PostgreSQL)	Inyección SQL	Consultas nativas y procedimientos almacenados no auditados; JPA/Hibernate mitigante pero no cubre 100%	2	4	8 (Alto)	JPA/Hibernate con parámetros tipados	Auditoría de todas las consultas nativas. WAF con reglas SQL injection. Pentest trimestral.	3
R-05	A-10 (Frontend), A-18 (Documentos)	Ataque XSS (Cross-Site Scripting)	Reportes exportados en PDF/HTML podrían inyectar scripts si datos no se sanitizan al generarlos	2	3	6 (Medio)	Sanitización automática de Angular en templates	CSP estricta en Nginx. Sanitizar datos antes de generar PDFs/Excel. Validación en backend.	5
R-06	A-21 (Nginx), A-22 (EC2)	Ataque de denegación de servicio (DoS/DDoS)	Instancia EC2 con un solo punto de entrada (Nginx) sin protección volumétrica ni escalado	3	3	9 (Alto)	Ninguno	AWS WAF + AWS Shield Standard. Rate limiting en Nginx. CloudFront como CDN con protección DDoS.	2

R-07	A-09 (Kafka)	Acceso no autorizado a Kafka	Kafka sin autenticación ni cifrado. Cualquier servicio en la misma VPC podría producir/consumir del topic	2	3	6 (Medio)	Aislamiento por Security Group (solo SG-App accede a puerto 9092)	SSL/TLS en Kafka. SASL/SCRAM para autenticación. Migrar a Amazon MSK.	4
R-08	A-01 (PostgreSQL), A-04 (Backend), A-08 (Notif.), A-09 (Kafka)	Intercepción de tráfico interno VPC	Tráfico entre servicios viaja en texto plano dentro de la VPC. Atacante con acceso a la instancia podría capturarlo	2	3	6 (Medio)	Aislamiento de VPC	SSL/TLS en PostgreSQL (ssl=true). Cifrar comunicación con Kafka.	4
R-09	A-07 (AuditLog), A-01 (PostgreSQL)	Fuga de datos por error en registro de auditoría	lab_auditoria registra datos sensibles (oldData, newData) sin cifrar en columnas	2	4	8 (Alto)	Control de acceso a BD por Security Group	Cifrar columnas sensibles en lab_auditoria (pgcrypto). Política de retención: purge automático > 1 año.	3
R-10	A-05 (JWT), A-24 (Admin), A-25 (Usuarios)	Suplantación de identidad (token theft)	Token JWT almacenado en localStorage. Un XSS o script malicioso de extensión podría robarlo	3	4	12 (Crítico)	Token con expiración 30 min. Refresh token con rotación	Migrar token de localStorage a HttpOnly cookie (Secure + SameSite=Strict). Boundary tokens (vincular token a IP + User-Agent).	1
R-11	A-22 (EC2)	Acceso root a instancia EC2 por SSH expuesto	Puerto SSH (22) abierto a internet. Si IP del administrador es comprometida o cambia, la instancia queda accesible	2	4	8 (Alto)	Security Group restringe SSH a IP del administrador	Deshabilitar SSH por internet. Usar solo AWS SSM Session Manager (sin puertos abiertos, con auditoría).	2
R-12	A-01 (PostgreSQL), A-02 (Migraciones)	Corrupción de BD por migración fallida	Migraciones Flyway se ejecutan automáticamente al iniciar el backend sin validación previa en staging	2	4	8 (Alto)	Flyway out-of-order=false. Snapshots diarios EBS	Entorno staging para validar migraciones. Checksums de integridad. Scripts de rollback.	3
R-13	A-16 (Datos personales)	Violación de datos personales (Ley 29733)	BD almacena DNI, direcciones, datos personales sin cifrado a nivel de columna	2	4	8 (Alto)	Cifrado en reposo del volumen EBS. Control de acceso por roles	Cifrado a nivel de columna (pgcrypto) para DNI y direcciones. Enmascarar datos personales en logs y auditoría.	3
R-14	A-05 (JWT), A-24, A-25	Suplantación de sesión por fijación (session fixation)	Token JWT no se renueva después de cambio de sucursal/punto de venta	1	3	3 (Bajo)	Token incluye idSucursal e idPunto como claims	Renovar token JWT completo después de cada cambio de sucursal (verificar implementación en AuthSucursalService).	5
R-15	A-04 (Backend), A-24, A-25	Falta de segregación de funciones (SOD)	Un mismo usuario podría crear y aprobar una misma operación si tiene los roles combinados	2	3	6 (Medio)	Control de permisos por rol (@PreAuthorize)	Implementar matriz SOD: reglas de conflicto (creador ≠ aprobador). Validar SOD antes de asignar roles.	4

Distribución estadística de riesgos

Métrica	Valor
Total de riesgos identificados	15
Riesgos críticos (12–16)	2 (13%)
Riesgos altos (8–9)	8 (54%)
Riesgos medios (4–6)	4 (27%)
Riesgos bajos (1–3)	1 (6%)
Promedio de probabilidad	2.2 / 4
Promedio de impacto	3.5 / 4
Riesgo residual promedio (post-control)	4.1 / 16

Costo estimado de implementación de controles

Tipo de control	Costo mínimo	Costo con servicios gestionados AWS
Configuración de software libre (Nginx, CSP, hardening)	USD 0	USD 0
Gestión de secretos (Secrets Manager)	—	~USD 4/mes
WAF + rate limiting	—	~USD 20/mes
AWS Shield Advanced (DDoS)	—	~USD 3,000/año (Shield Standard es gratuito)
CloudFront (CDN + DDoS)	—	~USD 0.085/GB + USD 0.01/10k requests
SSM Session Manager	USD 0	USD 0
pentest trimestral externo	~USD 1,500 – 3,000 por sesión	—
Total mensual (servicios AWS adicionales)	USD 0	~USD 25 – 50/mes

Anexo B: Referencias a estándares

B.1 Estándares internacionales de seguridad

Estándar	Versión	Descripción	Aplicación en Finanzas
ISO/IEC 27001	2022	Sistema de Gestión de Seguridad de la Información (SGSI). Requisitos para establecer, implementar, mantener y mejorar un SGSI.	Base del plan de seguridad. Los controles propuestos en las Secciones 3 y 5 se alinean con los anexos A.5–A.18 de ISO 27001:2022.
ISO/IEC 27002	2022	Código de buenas prácticas para controles de seguridad de la información.	Guía para la implementación de los controles del Anexo A de ISO 27001. Referencia directa para políticas de control de acceso (P-AC), cifrado (P-DT) y gestión de incidentes (P-IN).
ISO/IEC 27005	2022	Gestión de riesgos de seguridad de la información.	Metodología utilizada en la Sección 2 para la identificación, análisis y evaluación de riesgos. Define el proceso de identificación de activos, amenazas, vulnerabilidades y cálculo de riesgo.
ISO/IEC 27017	2015	Guía de controles de seguridad para servicios cloud (extensión de ISO 27002).	Aplica directamente al despliegue sobre AWS. Los controles específicos para cloud (CLD 1–CLD 37) se reflejan en las políticas de seguridad de red (P-RD), gestión de secretos (P-CR) y responsabilidad compartida (P-FI).
ISO/IEC 27018	2019	Protección de datos personales en servicios cloud.	Aplica al tratamiento de datos personales (A-16). Los controles P-DT-02 (cifrado en reposo), P-DT-05 (minimización de datos) y P-DT-06 (enmascaramiento) se alinean con este estándar.
ISO/IEC 27701	2019	Extensión de ISO 27001 e ISO 27002 para la gestión de información de privacidad.	Marco para el sistema de gestión de privacidad (PIMS). Relacionado con el rol del DPO y el cumplimiento de Ley 29733.
NIST SP 800-30	Rev. 1	Guide for Conducting Risk Assessments.	Metodología complementar a ISO 27005. Utilizada para la definición de las escalas de probabilidad e impacto y el cálculo del nivel de riesgo en la Sección 2.
NIST SP 800-53	Rev. 5	Security and Privacy Controls for Information Systems and Organizations.	Catálogo de controles de seguridad. Controles específicos aplicables: AC-1 (Policy and Procedures), AC-2 (Account Management), AC-3 (Access Enforcement), AU-1 (Audit and Accountability), SC-8 (Transmission Confidentiality and Integrity), SC-12 (Cryptographic Key Management).
NIST SP 800-61	Rev. 2	Computer Security Incident Handling Guide.	Guía para el proceso de gestión de incidentes. Referencia directa para la política P-IN-03 (procedimiento de respuesta) y el ciclo PDR.
NIST SP 800-115	2007	Technical Guide to Information Security Testing and Assessment.	Guía para la realización de pruebas de seguridad y pentests. Referencia para P-AP-05.

PCI DSS	4.0	Payment Card Industry Data Security Standard.	Aplicación condicional: Si el sistema llega a procesar, almacenar o transmitir datos de tarjetas de crédito/débito, deberá cumplir con PCI DSS. Actualmente no aplica porque el sistema no maneja pagos con tarjeta directamente.
OWASP Top 10	2021	Proyecto Abierto de Seguridad en Aplicaciones Web — Top 10 vulnerabilidades más críticas.	Referencia directa en P-AP-02. Cada vulnerabilidad del Top 10 tiene un control asociado en el sistema: Inyección (JPA parametrizado), Autenticación (JWT + RSA), Exposición de datos (cifrado), XSS (CSP + sanitización Angular), etc.
OWASP ASVS	4.0.3	Application Security Verification Standard.	Marco para verificar el nivel de seguridad de las aplicaciones. Nivel de aseguramiento objetivo: ASVS Nivel 2 (estándar para aplicaciones que manejan datos sensibles).
OWASP Testing Guide	4.2	Guía de pruebas de seguridad para aplicaciones web.	Metodología para las pruebas de penetración trimestrales (P-AP-05).

B.2 Estándares de redes y comunicaciones

Estándar	Versión	Descripción	Aplicación en Finanzas
IEEE 802.1Q	2022	Redes de área local virtuales (VLAN).	Equivalente funcional implementado mediante VPC con 4 subredes y Security Groups (ver CE0311, Sección 2.3).
IEEE 802.1X	2020	Control de acceso a la red basado en puertos.	Equivalente funcional: Security Groups + IAM controlan qué entidades pueden comunicarse en cada puerto.
IEEE 802.3	2022	Estándar Ethernet.	Capa física gestionada por AWS. La ENI de la instancia EC2 opera sobre esta capa.
TLS 1.3	RFC 8446	Transport Layer Security — última versión del protocolo de cifrado en tránsito.	Objetivo: TLS 1.3 para todas las comunicaciones HTTPS. Mínimo aceptable: TLS 1.2. Prohibido: TLS 1.0, TLS 1.1, SSL 3.0.

B.3 Normativa legal peruana

Normativa	Descripción	Aplicación en Finanzas
Ley N.º 29733	Ley de Protección de Datos Personales (Perú, publicada el 3 de julio de 2011).	Marco legal principal para el tratamiento de datos personales en el sistema. Aplica a A-16 (datos personales de empleados, clientes, proveedores). Referencia directa en políticas P-DT y rol DPO.

Decreto Supremo N.° 003-2013-JUS	Reglamento de la Ley N.° 29733.	Especifica los procedimientos para el registro de bancos de datos, consentimiento, flujo transfronterizo y notificación de violaciones.
Resolución Directoral N.° 019-2013-JUS/DGPDP	Directiva de Seguridad de la Información para Bancos de Datos Personales.	Define las medidas de seguridad técnicas y organizativas que deben implementar los bancos de datos personales. Referencia directa para las políticas de cifrado (P-DT), control de acceso (P-AC) y gestión de incidentes (P-IN).
Ley N.° 27269	Ley de Firmas y Certificados Digitales (Perú).	Aplica si el sistema se integra con comprobantes electrónicos (facturación SUNAT). El diseño de red soporta mTLS para comunicación con OSE/OPE.
Ley N.° 28194	Ley de Lucha contra la Evasión y Formalización de la Economía (Perú).	Relacionada con los montos máximos de operaciones en efectivo y la obligatoriedad de usar medios de pago formales. Aplica a los módulos de caja y cuentas corrientes.

B.4 Marcos de buenas prácticas cloud

Marco	Descripción	Aplicación en Finanzas
AWS Well-Architected Framework	Marco de buenas prácticas para arquitecturas cloud, basado en 6 pilares: Excelencia Operacional, Seguridad, Confiabilidad, Eficiencia de Rendimiento, Optimización de Costos y Sostenibilidad.	Los 6 pilares se cubren explícitamente en el diseño de infraestructura (CE0311, Sección 4.5) y se refuerzan con controles de seguridad específicos en este documento.
AWS Shared Responsibility Model	Modelo que define qué es responsabilidad de AWS (seguridad del cloud) y qué es responsabilidad del cliente (seguridad en el cloud).	Marco rector de todo el plan de seguridad. AWS responde por la capa física; el equipo Finanzas responde por la configuración lógica, el código y los datos.
CIS Benchmarks	Guías de hardening para sistemas operativos, bases de datos y servicios cloud del Center for Internet Security.	Referencia para el hardening de: Ubuntu 24.04 LTS (CIS Benchmark), PostgreSQL 16 (CIS Benchmark), Docker (CIS Benchmark).
CIS AWS Foundations Benchmark	Guía de hardening específica para cuentas AWS.	Aplica a la configuración de la cuenta AWS: IAM, CloudTrail, CloudWatch, S3, VPC.
CAF (Cloud Adoption Framework)	Marco de AWS para la adopción de cloud, incluyendo perspectivas de seguridad y cumplimiento.	Marco organizacional para la gestión del cambio y la adopción de controles cloud en la organización.

B.5 Correspondencia entre controles propuestos y estándares

Control propuesto	ISO 27001:2022	NIST SP 800-53	OWASP	PCI DSS 4.0
-------------------	----------------	----------------	-------	-------------

Rate limiting en login	A.9.4.1	AC-7	A2: Authentication Failures	8.3.2
Gestión de secretos (Secrets Manager)	A.8.1.1, A.10.1.2	SC-12, SC-28	—	3.5.1
Cifrado en reposo (EBS + S3)	A.10.1.1	SC-28	—	3.4
Cifrado en tránsito (TLS 1.2+)	A.10.1.2	SC-8	A3: Sensitive Data Exposure	4.2.1
WAF + reglas de inyección	A.14.2.5	SI-10	A1: Injection, A3: Injection	6.5.1
CSP (Content Security Policy)	A.14.2.5	SC-7	A5: XSS	6.5.1
Auditoría de operaciones (lab_auditoria)	A.8.15, A.12.4.1	AU-2, AU-3	A9: Insufficient Logging	10.2.1
Boundary tokens (vincular JWT a IP/UA)	A.9.2.1	AC-2, AC-3	A1: Broken Access Control	8.2.1
Matriz SOD (segregación de funciones)	A.9.2.3	AC-5	—	7.2.1
Hardening de servidores (CIS)	A.8.9, A.12.6.1	CM-6, SI-2	A6: Vulnerable Components	6.3.1
VPC Flow Logs + CloudWatch	A.8.15, A.12.4.1	AU-12, SI-4	A9: Insufficient Logging	10.3.1
Plan de respuesta a incidentes	A.5.24, A.5.25, A.5.26	IR-4, IR-5, IR-6	—	12.10.1
Pentest trimestral	A.14.2.7, A.14.2.8	CA-8, RA-5	—	11.4.1
SSM Session Manager (sin SSH público)	A.9.2.1, A.9.4.2	AC-3, AC-6	—	7.2.1